

LLM Cybersecurity Program Mapping to Security Frameworks

Duke Cybersecurity Program

Abstract

This proposal describes a Proof of Concept (PoC) tool that uses a Large Language Model (LLM) to semi-automate cybersecurity maturity assessments for organizations. The tool maps an organization's internal cybersecurity policies and procedures against widely recognized security frameworks, such as the NIST Cybersecurity Framework (CSF), NIST 800-53, ISO 27001, CIS Critical Security Controls (CSC), CMMC, CSA-CCM, FTC Safeguards Rule, HIPAA, and PCI-DSS, and produces a structured gap analysis with recommended remediation priorities. Critically, this tool is designed to augment, not replace, the judgment of security professionals. Outputs are presented as decision-support artifacts, reviewed and validated by a qualified human analyst before being acted upon.

1.0 Background

1.1 The Challenge of Manual Cybersecurity Assessments

Cybersecurity maturity assessments are essential for organizations seeking to understand their preparedness against evolving threats. Yet in practice, they are costly, time-intensive, and demand specialist knowledge across multiple frameworks simultaneously. A single NIST CSF assessment can cost between \$5,000 and \$115,000 and spans several weeks of structured analyst effort, from pre-engagement scoping through evidence review to final reporting. ISO 27001 certification, often pursued in parallel, adds a further \$50,000 to \$150,000. It is therefore unsurprising that nearly 70% of service organizations now need to demonstrate compliance across at least six frameworks simultaneously (Coalfire, 2023), a figure that rises each year as new regulations emerge.

The structural conditions driving this burden are well-documented. The global cybersecurity workforce gap stood at 4.8 million professionals in 2024, a 19% year-on-year increase, with 90% of organizations reporting skills shortages within their security teams (ISC2, 2024). Cyber incidents rank as the top operational threat across sectors (Allianz Risk Barometer, 2024), yet the capacity to assess and address them continuously remains constrained. The consequences are measurable: 40% of organizations report security incidents as a consequence of reactive or manual compliance approaches (Drata, 2023), and the average cost of a data breach reached \$4.88 million in 2024 (IBM, 2024). For organizations operating under resource pressure, the overhead of continuous, multi-framework assessment is not merely inconvenient; it is structurally unachievable.

1.2 Existing Research and Relevant Literature

This project builds on a convergent body of scholarship spanning GRC automation, large language model applications in cybersecurity, retrieval-augmented generation, cybersecurity maturity frameworks, and human-in-the-loop AI governance. Several findings from this literature directly inform our methodology and architectural decisions.

Research on compliance automation establishes that organizations subject to multiple concurrent regulatory regimes face exponentially greater complexity than those governed by a single standard (Mohammed, 2025), and that AI-driven workflows can substantially reduce assessment time and minimize the inconsistencies introduced by manual review (Pinninti, 2025; Pillai & Kumar, 2024). Essien et al. (2025) further confirm that AI-driven systems can process data volumes and complexity that routinely overwhelm human analysts, validating the efficiency case for automated maturity assessment tooling at scale.

On the technical side, LLM-based tools have been shown to materially outperform keyword-matching and rule-based systems in identifying compliance gaps within security policy documents (Cadet et al., 2024), and RAG architectures consistently outperform standard LLM inference on knowledge-intensive tasks by grounding outputs in retrieved authoritative context rather than training data alone (Zhang et al., 2025). These findings validate the core pipeline design: document-grounded retrieval as the primary hallucination mitigation strategy, combined with structured outputs that make each assessment traceable and auditable by a human reviewer.

The literature is equally consistent on governance. Research across explainable AI and compliance automation frames human oversight not as a downstream control but as a first-class design requirement for AI systems operating in consequential, regulated domains (Edgar et al., 2025; Oriaro & Mishra, 2025). The EU AI Act's emerging mandates for high-risk AI systems reinforce this direction, requiring documented transparency, bias detection, and meaningful human review. Our architecture reflects these findings directly: low-confidence mappings are surfaced for mandatory analyst evaluation, all interactions are logged for auditability, and no output is finalized without explicit analyst sign-off. A complete literature review, including full citations and gap analysis, is provided as a project appendix.

2.0 Project Objectives

2.1 Primary Objectives

This proof of concept serves three core pillars:

1. **Maturity Scoring:** Implement a maturity scoring model based on a defined, transparent methodology that produces an overall posture score and per-domain subscores, enabling organizations to identify and prioritize gaps across assessed frameworks.
2. **Human-Validated Output:** Ensure all automated outputs are reviewed and attested by a qualified analyst before being presented as findings, mitigating risks of hallucination, misclassification, and false positives inherent to LLM-generated assessments.
3. **Practical Demonstration:** Deliver a working proof of concept with documented findings and ratified performance metrics, with supporting documentation sufficient for evaluating applicability within real organizational contexts.

2.2 Deliverables

The project will produce a proof-of-concept tool that evaluates cybersecurity policies and controls against established frameworks. Supporting documentation will be delivered in the form of reports and presentations that capture the project's objectives, methodology, architecture decisions, evaluation results, and findings as the project progresses.

2.3 Initial Scope

This PoC is scoped to validate the model in a controlled, bounded environment before extension to additional frameworks, sectors, or regulatory regimes. The initial PoC will support widely adopted, industry recognized frameworks such as (but not limited to) the NIST CSF and the ISO 27001:2022.

Additionally, rather than making claims about replacing expertise, this tool is designed to help organizations make more informed decisions by:

- Providing a structured, reproducible starting point for maturity assessments that a human analyst can verify and build upon.
- Prioritizing remediation activities by identifying the highest-impact gaps relative to each organization's applicable frameworks.

- Reducing the time required for initial document review, freeing analyst time for the operational validation activities that documentation analysis cannot capture.
- Supporting regulatory compliance preparation for HIPAA, PCI-DSS, and similar frameworks by surfacing specific control gaps with document-level evidence.

2.4 Scope Exclusion

Several capabilities fall explicitly outside the scope of this PoC. The tool does not assess operational security posture; activities such as SIEM log analysis, endpoint telemetry review, and penetration testing interpretation remain the domain of human-led processes; well-written policies are necessary but not sufficient evidence of maturity. The tool likewise does not support real-time or continuous monitoring, producing point-in-time assessments only. Outputs are advisory and do not constitute legal or regulatory compliance certification. Finally, the system is not designed to process classified or highly sensitive organizational data.

2.5 Success Criteria

At a high level, success will likely be evaluated across two primary dimensions: accuracy, or how well the system's outputs align with expert judgment on cybersecurity policy and control assessments, and efficiency, meaning the degree to which the tool reduces the time and effort required compared to manual assessment processes.

Where comparable prior work or published benchmarks exist, the project will reference those as additional points of calibration. Specific thresholds and benchmarks will be formalized in the design specification once the scoring methodology and evaluation dataset are established. At this stage, candidate metrics include mapping accuracy relative to expert-labeled ground truth, and time reduction compared to baseline manual assessment processes.

3.0 Technical Design

3.1 System Architecture & Pipeline

The pipeline consists of four stages. A design document with detailed specifications will be produced in Phase 1 and maintained throughout development.

#	Stage	Note
1	Document Ingestion	Organizational policy documents submitted by the user are processed and prepared for analysis. The system is designed to ensure that all outputs remain grounded in the actual content of the submitted documents, enabling human reviewers to verify findings against their source material.
2	Framework Mapping	The system analyzes the ingested documents against the controls defined in the target cybersecurity frameworks. For each control, the system produces a coverage determination and a confidence indicator. Low-confidence mappings are flagged for human review.

3	Maturity Scoring	Coverage determinations are aggregated into an overall maturity assessment. The scoring methodology will be defined during the design phase, with the goal of producing results that are transparent and auditable. Candidate approaches under consideration include CMMI-inspired tiered scales and CIS Implementation Group structures, with final methodology selection deferred to the design specification.
4	Report Generation	The system produces a structured output report summarizing the assessment findings, including maturity scores, identified gaps, and recommended remediation priorities. All outputs are advisory and require analyst review before being treated as final findings.

The following candidate tools are under consideration across each component of the system. Final selections will be based on their demonstrated contribution to performance, cost-effectiveness, and overall feasibility, and will be documented in the design specification as the project progresses.

- **LLMs:** The core language model(s) responsible for reasoning and response generation. Candidates include both open-source options (e.g., Llama 3, Mistral, Falcon) and commercial APIs (e.g., OpenAI, Anthropic). Final selection will be based on factors such as cost, performance, licensing, and ease of integration.
- **RAG Framework:** Manages document chunking, embedding, and retrieval. Options include frameworks such as LangChain and LlamaIndex. Final selection will depend on factors such as flexibility, community support, and compatibility with other chosen components.
- **Embedding Model:** Converts text into vector representations for semantic search and retrieval. Options include open-source models (e.g., sentence-transformers) as well as API-based alternatives. Final selection will be guided by accuracy, latency, and cost.
- **Compute:** Infrastructure for local inference, development, and testing. Options include personal laptops, Duke lab space (Hudson), and available GPU resources (Nvidia Spark etc.). Final allocation will depend on model size and workload requirements.
- **Code Repository:** Version-controlled storage for all project code. Options include platforms such as GitHub. Final selection will account for access control requirements, collaboration features, and institutional constraints.
- **Frameworks & Libraries:** Supporting tools for model loading, training, and inference. Options include libraries such as Hugging Face Transformers, PyTorch, and the broader Python ecosystem. Final selection will follow from the chosen models and infrastructure.

3.2 Timeline

This project will be showcased at two key events: the CISO Certificate Program in June and the Duke Cybersecurity Conference in September. Accordingly, the timeline prioritizes establishing a functional proof of concept by June, with post-implementation testing and refinement completed ahead of the September conference. The official project kickoff is Mid-March (approximately March 15th). The table below outlines the focus and expected deliverables at each phase.

Phase	Weeks	Key Activities	Deliverables
Phase 1 Research & Design	1-4 (Mid-April)	Establish project foundations Update the project proposal Conduct a revised literature review. Begin research and exploratory testing of candidate technical architectures.	Updated Project Proposal Updated Literature Review Initial Technical Design Specifications
Phase 2 Development	5-8 (Mid-May)	Finalize tool selections per the design specification	Functional PoC prototype, Developed Technical Design Specifications

		Build core pipeline components including document ingestion, embedding, retrieval, and LLM integration Stand up initial end-to-end prototype	
Phase 3 Testing & Validation	9-12 (Mid June)	Evaluate system performance against defined metrics Conduct user testing and gather stakeholder feedback Prepare demonstration for the CISO Certificate Program showcase	Evaluation Report CISO Showcase Demonstration
Phase 4 Improvements	13-16 (Mid July)	Incorporate feedback from testing and the June showcase Refine retrieval quality, response accuracy, and UX Address any identified gaps in coverage or performance	Improved PoC build Updated Evaluation Results
Phase 5 Project Close	17-20 (Mid August)	Finalize documentation and prepare conference materials Conduct final validation and stakeholder review Present at the Duke Cybersecurity Conference	Final Project Documentation Conference Presentation

This timeline and its associated deliverables are tentative and subject to change as the project evolves. It is intended as a rough guide rather than a fixed plan.

3.3 Personnel List

The following personnel constitute the current project team. Once again note that this is not a fixed list, and may change as the project progresses.

Note	Affiliation	Position	Role
Dr. Karen Schnell	Duke University	Adjunct Professor in the Engineering Graduate and Professional Programs	Faculty Supervisor
Dr. Arturo Ehuan	Duke University	Executive Director, Cybersecurity Master's Program	Faculty Supervisor
Dr. Eduardo Rodrigues	Instituto Tecnológico de Aeronáutica	Visiting Research Scholar	Faculty Supervisor
Anthony Ngari	Duke University	Masters Student, Data Science	Research Assistant
Jenson Goh	Duke University	Masters Student, Cybersecurity	Research Assistant
Catalina Pena	Florida State University	Undergraduate Student, Cyber Criminology	Research Assistant
Amal Jadoon	Duke University	Masters Student, Cybersecurity	Research Assistant

4.0 Additional Considerations

4.1 Security, Access, and Confidentiality

Security, access control, and data confidentiality are recognized as foundational considerations within this PoC, given the sensitive nature of the documents involved. These aspects have been fully considered and will be appropriately addressed.

Safeguards and controls will be implemented to ensure documents are handled and managed responsibly, with a focus on maintaining confidentiality, integrity, and controlled access. Detailed specifications and implementation approaches are documented separately in the relevant design and technical materials.

4.2 Human-in-the-Loop Requirement

Human oversight is a core design principle of this PoC. No system-generated output will be presented as a final assessment without review and explicit sign-off by a qualified analyst. The tool is intended to act as a force multiplier for expert judgment, not a replacement for it.

Accordingly, the human review checkpoint is treated as a first-class component of the system rather than a downstream control. The review interface will be designed to systematically surface low-confidence or ambiguous mappings for mandatory evaluation, while enabling analysts to override, annotate, or escalate findings as needed. Finalization of any report will require explicit analyst approval, and all such interactions will be logged to support auditability, traceability, and ongoing model improvement.

4.3 Hallucinations

Hallucinations, which are confident yet incorrect outputs, are a real and material concern in LLM-driven document analysis. This PoC treats hallucination risk as a first-order reliability issue and will employ a range of mitigation techniques, of which further details on implementation, evaluation, and observed effectiveness will be highlighted in the technical design documents.

5.0 Closing Remarks

5.1 Closing Remarks

The proposed LLM-based maturity assessment tool represents a critical step toward addressing the structural bottlenecks inherent in manual cybersecurity compliance. By leveraging a human-in-the-loop architecture, this project seeks to balance the high-speed processing capabilities of Large Language Models with the indispensable nuance of expert human judgment.

Ultimately, this Proof of Concept aims to demonstrate that automated mapping and gap analysis can transform cybersecurity assessments from a costly, periodic overhead into a reproducible and efficient operational standard. As the threat landscape evolves and regulatory burdens increase, such tools will be vital in ensuring organizations can maintain a resilient security posture without being overwhelmed by the complexities of multi-framework compliance.

A.0 Appendix

A.1 References

Allianz Commercial. (2024). *Allianz Risk Barometer 2024: Identifying the major business risks for 2024*. Allianz Global Corporate & Specialty.

<https://commercial.allianz.com/news-and-insights/reports/allianz-risk-barometer.html>

Cadet, E., Etim, E. D., Essien, I. A., Erigha, E. D., Babatunde, L. A., Ajayi, J. O., & Obuse, E. (2024). Large language models for cybersecurity policy compliance and risk mitigation. *International Journal of Scientific Research in Humanities and Social Sciences*. <https://doi.org/10.32628/IJSRSSH242560>

Coalfire. (2023). The state of cybersecurity compliance in 2023: Part 1. *Coalfire Blog*. <https://coalfire.com/the-coalfire-blog/the-state-of-cybersecurity-compliance-in-2023>

Drata. (2023). *2023 Compliance Trends Report*. Drata Inc. <https://drata.com/compliance-trends>

Edgar, T., Lowell, E., Winslow, C., & Harlan, T. (2025). Automated risk scoring models for security compliance using AI and behavioral analysis. ResearchGate. <https://www.researchgate.net/publication/398660985>

Essien, I. A., Cadet, E., Ajayi, J. O., Erigha, E. D., & Obuse, E. (2025). AI-driven continuous compliance and threat intelligence model for adaptive GRC in complex digital ecosystems. *Computer Science & IT Research Journal*, 6(7). <https://www.researchgate.net/publication/394998384>

IBM Security. (2024). *Cost of a data breach report 2024*. IBM Corporation. Conducted by Ponemon Institute. <https://www.ibm.com/reports/data-breach>

ISC2. (2024). *ISC2 cybersecurity workforce study 2024*. ISC2. <https://www.isc2.org/Insights/2024/10/ISC2-2024-Cybersecurity-Workforce-Study>

Mohammed, A. R. (2025). Critical compliance challenges across industries and the role of automation. ResearchGate. <https://www.researchgate.net/publication/394471615>

Oriaro, S., & Mishra, S. (2025). Improving cybersecurity through explainable artificial intelligence: A systematic literature review. *Issues in Information Systems*, 26(3), 387–400. https://doi.org/10.48009/3_iis_2025_2025_131

Pillai, A. V., & Kumar, K. (2024). The impact of AI-based compliance automation on regulatory audit readiness. ResearchGate. <https://www.researchgate.net/publication/397454385>

Pinninti, V. P. (2025). Automating governance, risk, and compliance (GRC) in cloud computing: A case study on ServiceNow and NIST framework integration. https://www.researchgate.net/publication/397029207_Automating_Governance_Risk_and_Compliance_GRC_in_Cloud_Computing_A_Case_Study_on_ServiceNow_and_NIST_Framework_Integration

Zhang, J., Bu, H., Wen, H., Liu, Y., Fei, H., Xi, R., Li, L., Yang, Y., Zhu, H., & Meng, D. (2025). When LLMs meet cybersecurity: A systematic literature review. *Cybersecurity*, Springer Nature. <https://link.springer.com/article/10.1186/s42400-025-00361-w>

A.2 Acronyms

Acronym	Full Term
LLM	Large Language Model
PoC	Proof of Concept
NIST CSF	National Institute of Standards and Technology Cybersecurity Framework
NIST 800-53	NIST Special Publication 800-53 (Security and Privacy Controls)
ISO 27001	International Organization for Standardization 27001 (Information Security Management)
CIS CSC	Center for Internet Security Critical Security Controls
CMMC	Cybersecurity Maturity Model Certification
CSA-CCM	Cloud Security Alliance Cloud Controls Matrix
FTC	Federal Trade Commission
HIPAA	Health Insurance Portability and Accountability Act
PCI-DSS	Payment Card Industry Data Security Standard
RAG	Retrieval-Augmented Generation
IAM	Identity and Access Management
SIEM	Security Information and Event Management
SME	Small and Medium-Sized Enterprise
IG1/IG2/IG3	CIS Controls Implementation Groups (scaling tiers by org size/complexity)
CMMI	Capability Maturity Model Integration